

第六輪小白卡關修補法律與合規警告 (v3.42)



本檔性質：使用者帳號管理 / 全域搜尋 / 附件 / per-user 限額 / 工作天 / transcript / 時區之合規提醒 · 不構成法律意見。累積適用於 v3.25.10 → v3.41 全部 §6 聲明。

English version: [POLISH_V342_LEGAL_NOTICE_EN.md](#)

⚠️ 客戶務必由 IT / 法律 / HR 主管覆核後正式上線。

⚠️ v3.42 涉及之結構性敏感功能

功能	風險等級	影響範圍
使用者帳號 建立 / 停用 (R1)	● 全系統存取控制	HR 月月用 + 資安
附件連結到單據 (R3)	● 著作權 / 機密	法務 / 內控
AI 每人每日上限 (R4)	● 服務水準	全員影響
對話 transcript 匯出 (R6)	● 使用者輸入歷史	個資 / 商業機密
時區設定 (R7)	● 顯示層	全員
全域搜尋 (R2)	● 資料可見度	內控
工作天計算 (R5)	● 啟發式 helper	業務

1. 使用者帳號管理 (R1) ⚖️ 資安最敏感

1.1 行為

- LLM 講「給阿明開帳號」→ ConfirmCard → 建立 User row + 連結 Employee
- LLM 講「停用阿明帳號」→ ConfirmCard → User.is_active = False
- 不刪除資料 (保留 audit 軌跡)

1.2 法律 / 資安風險

- 權限與責任：

- 建立超級管理員 = 賦予不受限制之系統存取權
- 停用帳號 = 立即剝奪該員工存取權 (即使在工作時間中)
- 此操作之法律意義等同於：給/收離職員工的辦公室鑰匙
- 未即時停用之風險：
 - 員工離職但帳號未停 → 可能繼續操作系統 (盜取資料、修改紀錄)
 - 屬於《個人資料保護法施行細則》§12「資料安全維護措施」之違反
 - ISO 27001 / CMMI 認證會直接 fail
- 誤建超級管理員之風險：
 - 一旦給予 `is_superuser=True` → 該帳號繞過所有 RBAC
 - 包括：刪除老闆的客戶、改自己的薪資 (若有 payroll)、清空 audit log
 - 取消方式：另一個超級管理員把他降權，但若只剩這個超管 + 他離職 → 系統失控

1.3 客戶內控義務 (強制)

- ☐ 限制 `system.config.update` 權限給老闆 + 1 名 IT 主管
- ☐ 建立「新員工帳號開立」書面審批流程 (HR + 部門主管 + IT 三方核章)
- ☐ 建立「離職員工帳號停用」SOP (離職當日下午班前必停)
- ☐ 超級管理員至少保留 2 個 (避免單點故障)
- ☐ 每季稽核未啟用 / 高權限帳號清單

1.4 密碼初始化

- 系統強制：≥ 8 字元、含英文 + 數字
- 客戶須告知員工：首次登入立即改密碼
- 老闆不應用 LINE / Email 傳明文密碼 → 用安全管道 (如紙條面交、加密訊息)

1.5 erpilot 免責

erpilot 對因未即時停用離職員工所致之資安事件、誤建超管所致之系統失控、密碼傳遞不當所致之外洩，於適用法律所允許之最大範圍內不承擔責任。

2. 附件連結到單據 (R3)

2.1 行為

- 把已上傳的 Attachment 連結到指定 SO / PO / Quote
- 寫入 `Attachment.parsed_target_type` + `parsed_target_id`

2.2 著作權風險

- 附件可能含**第三方著作權內容** (廠商寄來的規格書 / 設計圖)
- 客戶**轉發**給其他第三方須**確認授權**
- 若附件含**競爭對手機密** (誤收 email) → 不應留存

2.3 個資風險

- 客戶寄來之附件可能含**個資** (合約 / 身分證影本)
- 適用個資法第 27 條「資料安全維護」
- 保存期應符合**法定保存** (商業會計法 §38 : 5 年)

2.4 客戶內控義務

- 附件分類 + 加密儲存
- 不外流 (同 v3.36 §2)
- 定期清理逾期附件

3. AI 每人每日上限 (R4)

3.1 行為

- middleware 攔截 `/api/chat-v2` 等 LLM endpoint
- 預設 200 次 / day / user
- 超過 → 回 HTTP 429 + 中文友善訊息
- UTC 00:00 自動重置

3.2 限制

- in-memory counter — 後端重啟清空
- 單一 worker — 多 worker 部署不共享 (v3.x 改 Redis)
- per-IP 計算當無 token — 同 IP 多人共用會誤判

3.3 設定方式

`backend/.env` 加：

```
AI_DAILY_LIMIT_PER_USER=500 # 預設 200
```

3.4 客戶責任

- 告知員工此限制 (避免員工臨時撞到上限慌張)

- 依據業務需求調整上限
- 若員工經常撞上限 → 可能流程設計不佳 (不是員工問題)

3.5 法律 / SLA 影響

- 上限為**啟發式保護**，不取代正式 SLA
- 客戶不應僅憑此功能保證「AI 不會燒爆」
- 仍須定期檢視 v3.38 `query_ai_cost_*` 真實用量

4. 對話 Transcript 匯出 (R6)

4.1 行為

- 匯出最近 N 天之 ConversationLog 為 markdown
- 含 user role / assistant role / timestamp / agent

4.2 風險

● transcript 含使用者輸入歷史，可能含：

- 客戶名 / 料件 / 訂單細節 (商業機密)
- 員工問句中之個人意見 / 抱怨 (個資 + 勞動法)
- 密碼錯誤嘗試 (雖系統不應 log，但風險仍在)

4.3 客戶內控義務

- 匯出後加密儲存
- 不轉發給非授權人員
- 若用於教育訓練：遮罩客戶 / 員工真名
- 若用於HR 評估：事前告知員工 (涉勞動法)

4.4 erpilot 免責

erpilot 對 transcript 之外流 / 誤用 / 用於非法目的，不承擔責任。

5. 時區設定 (R7)

5.1 行為

- 設定 Tenant.settings.timezone
- LLM 回答之日期 / 時間自動轉為該時區

- DB 仍存 UTC

5.2 限制

- 白名單僅常見時區 (Asia/Taipei / Tokyo / NY / London / UTC 等)
- DST (夏令時間) 由 Python zoneinfo 處理
- 不影響 DB 之 UTC 儲存 (其他工具仍須自行 format)

5.3 風險

- 跨時區交易 (如客戶在 EU · 廠在 TW) → 訂單日期可能誤判
- 客戶應統一時區策略

6. 全域搜尋 (R2)

6.1 行為

- 一次搜尋 客戶 + 料件 + 供應商 + 員工
- case-insensitive · 每表 N 筆

6.2 風險

- 全域搜尋可能讓低權限員工看見不該看到之資料
- 但僅顯示基本欄位 (編號 / 名稱) · 不顯示金額 / 個資詳情
- 完整資料仍須走各別查詢 + 權限檢查

6.3 客戶責任

- 限制 `user.profile.read` 不要給匿名 / 臨時人員
- 監控異常頻繁搜尋 (可能洩漏前兆)

7. 工作天計算 (R5)

7.1 行為

- 加減 N 個工作天 (自動跳過週末 + 台灣 2026 國定假日)
- 內建假日：元旦 / 春節 / 二二八 / 清明 / 勞動 / 端午 / 中秋 / 國慶

7.2 限制

- 僅 2026 年之台灣假日 hard-coded
- 2027 起需手動更新 (v3.x 路線圖：動態行事曆)

- 不含公司自訂假日 (如年中、年終休假)
- 不含特休 / 補休

7.3 風險

- 算錯交期 → 客戶 / 供應商爭議
- 客戶應人工覆核重要日期

7.4 erpilot 免責

工作天計算為啟發式 helper ; erpilot 對因算錯交期所致之契約違約、罰金、客戶投訴，不承擔責任。

8. 案例：常見錯誤使用模式

8.1 ❌ 不該做

- 隨意建立超級管理員 (沒書面審批)
- 員工離職當天不停用帳號
- 把客戶寄來的競爭對手附件存進系統
- 用對話 transcript 截圖員工抱怨給其他主管看
- 把 AI rate limit 上限設極低 (< 50) 讓員工無法工作

8.2 ✅ 應該做

- 開帳號三方審批 (HR + 部門主管 + IT)
- 離職員工當日下午前停用
- 收到陌生 email 附件先病毒掃描 + 識別來源才上傳
- 對話 transcript 用於教育先遮罩敏感資訊
- AI rate limit 依員工實際業務量設定 (建議 200-500)

9. 免責條款 (累積 v3.25.10 → v3.42)

於適用法律所允許之最大範圍內：

1. 使用者帳號管理 (R1) erpilot 對因未即時停用、誤建超管、密碼傳遞不當所致之資安事件、契約爭議、勞動爭議，不承擔責任。
2. 附件 (R3) erpilot 對附件之著作權合規、個資保護、競爭資訊處理，不承擔責任。
3. AI 每日上限 (R4) erpilot 之上限為啟發式保護，不取代正式 SLA ; 對因限額不當設定所致之業務延誤，不承擔責任。

4. Transcript 匯出 (R6) erpilot 對 transcript 外流、誤用、用於 HR 評估所致之爭議，不承擔責任。
5. 時區 (R7) erpilot 之時區設定為顯示便利；對跨時區交易誤判所致之損失，不承擔責任。
6. 全域搜尋 (R2) erpilot 之搜尋為啟發式索引；對低權限員工取得敏感資訊所致之損失，客戶應自行強化 RBAC。
7. 工作天計算 (R5) erpilot 之計算僅含 2026 台灣假日；對跨年 / 公司自訂假日算錯所致之損失，不承擔責任。

10. 客戶導入前 Checklist (v3.42 補強)

10.1 使用者帳號管理 (最重要)

- ☐ 已限制 `system.config.update` 給老闆 + 1 名 IT
- ☐ 已建立新員工開帳號之三方審批 SOP
- ☐ 已建立離職員工帳號停用 SOP (當日下班前)
- ☐ 超管帳號至少 2 個 (避免單點故障)
- ☐ 每季稽核未啟用 / 高權限帳號

10.2 AI 用量管理

- ☐ 已告知員工每人每日上限
- ☐ 已依業務量設定 `AI_DAILY_LIMIT_PER_USER`
- ☐ 每月對帳 AI cost (用 v3.38 `query_ai_cost_*`)

10.3 附件管理

- ☐ 已訂定附件分類 + 加密儲存 SOP
- ☐ 已訂定逾期附件清理規則
- ☐ 已訓練員工識別可疑附件

10.4 Transcript 用途

- ☐ 已告知員工：transcript 不作 HR 考核
- ☐ 已訂定敏感資訊遮罩流程

10.5 與既有 checklist 累積

- ☐ 已完成 v3.25.10 → v3.41 之全部 checklist

11. 國際法 / 跨國使用警告

地區	額外法律	對 v3.42 影響
EU EU	GDPR Art. 17 (刪除權)	帳號停用不夠 — 員工可要求真正刪除
us US	SOX (上市公司)	Audit log 須不可竄改 — 帳號停用要記
us US (CA)	CCPA	員工有「資料攜帶權」 — transcript 匯出須支援
cn China	PIPL	跨境傳輸 transcript 須單獨同意
jp Japan	APPI	帳號狀態變更須留紀錄至少 3 年

版本：v3.42 (2026-05-22) 作者：erpilot 法務團隊 (內部) 對應程式：

- `backend/app/agents/domains/polish_v342_tools.py` (7 LLM tools + helper)
- `backend/app/core/ai_rate_limit.py` (R4 middleware)
- `backend/app/main.py` (middleware wire-in)
- `backend/app/config.py` (AI_DAILY_LIMIT_PER_USER)
- `frontend-desktop/src/pages/Dashboard.tsx` (R8 mobile)